

安全加固报告 FIX-09：会话管理、登出与Cookie安全

修复漏洞类型：会话管理、登出与Cookie安全

修复小组：天亮了么

修复时间：2026-08-28

对应漏洞报告：VULN-09-会话管理、登出与Cookie安全

修复负责人：蒲云楷

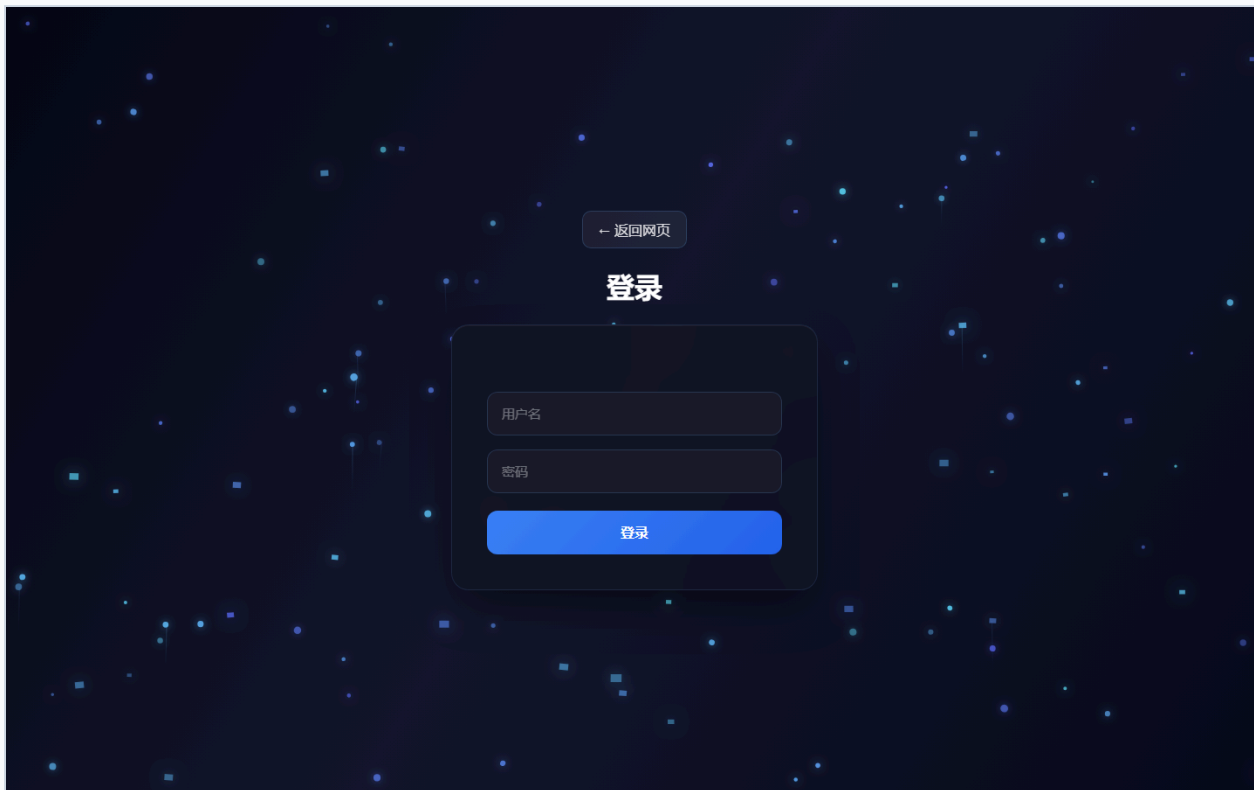
1. 基本信息

本报告按附录A记录阶段二任务9的修复和验证。

2. 漏洞复现情况

是否能按攻击方步骤复现：修复前基线已记录；修复后原始参数应被拦截或不产生越权效果。

复现环境：本机 127.0.0.1:5001。



云 个人网盘

首页文件相册传输分享

搜索文件、图片、视频

退出登录

纯

上传文件



野兽先辈

下北泽电子科技大学 学生

你的个人云盘首页

集中管理课程资料、图片、视频和个人文件。这里保留了原 profile 页面里的头像与视频内容，并改造成网盘首页布局。

开始上传

文件列表

24

年龄

1919114514

学号

VibeCoding

兴趣标签

全部文件

图片

视频

文档

收藏

回收站

空间使用

42.6 GB

已使用 42%，剩余空间充足

图片文件

排序

筛选



最近文件

列表

名称	类型	修改时间	大小
 课程资料	文件夹	今天 16:40	--
 数据库作业说明.docx	文档	昨天 21:18	1.8 MB
 首页设计参考.png	图片	5 月 16 日	3.4 MB
 项目演示视频.mp4	视频	5 月 15 日	128 MB

pyknb 的文件

上传新文件

返回个人主页

退出登录

文件名	操作
44286_2023_2_Fig5_HTML.webp	下载 删除
fake.png	下载 删除
scriptalert1_script.png	下载 删除

[← 返回网页](#)

登录

用户名

密码

登录

任务 09 修复代码证据

gets.py:195-215

```
195     if user and user[1].startswith(("pbkdf2:", "bcrypt:"))
196     else bool(user) and user[1] == password
197 )
198 if not valid:
199     record_login_failure(username)
200     response = {"error": "用户名或密码错误"}
201     return (jsonify(response), 401) if as_api else ("用户名或密码错误", 401)
202 clear_login_failures(username)
203 session.clear()
204 csrf_token()
205 session["username"] = username
206 if user and not user[1].startswith(("pbkdf2:", "bcrypt:")):
207     conn = get_db_connection()
208     try:
209         with conn.cursor() as cursor:
210             cursor.execute("UPDATE users SET password=%s WHERE username=%s", (generate_password_hash(password), username))
211             conn.commit()
212     finally:
213         conn.close()
214 security_logger.info("login_success username=%s ip=%s", username, client_ip())
215 if as_api:
```

gets.py:238-258

```
238
239 @app.post("/api/logout")
240 @csrf_protected
241 def api_logout():
242     session.clear()
243     return jsonify({"success": True})
244
245
246 @app.get("/profile")
247 def profile():
248     if "username" not in session:
249         return redirect("/login")
250     return render_template("profile.html")
251
252
253 @app.get("/logout")
254 def logout():
255     session.clear()
256     security_logger.info("logout ip=%s", client_ip())
257     return redirect("/")
258
```

3. 根因定位

相关文件： gets.py、相关模板和前端 API 客户端。

相关函数或接口： /login、/logout、/profile、/api/files；Flask Session。

问题代码/根因： 会话生命周期和 Cookie 属性需要显式安全配置。

4. 修复措施

修改点1

修改文件： gets.py。

修改前逻辑： 缺少统一安全边界或校验。

修改后逻辑： 启用 HttpOnly、SameSite=Lax 和可选 Secure；登录成功前清理旧 Session；退出 session.clear()；核心接口统一认证。

修改点2

修改文件：相关 HTML/CSS/前端 API（按任务适用）。

修改后逻辑：页面和客户端与服务端安全校验保持一致，不能替代服务端校验。

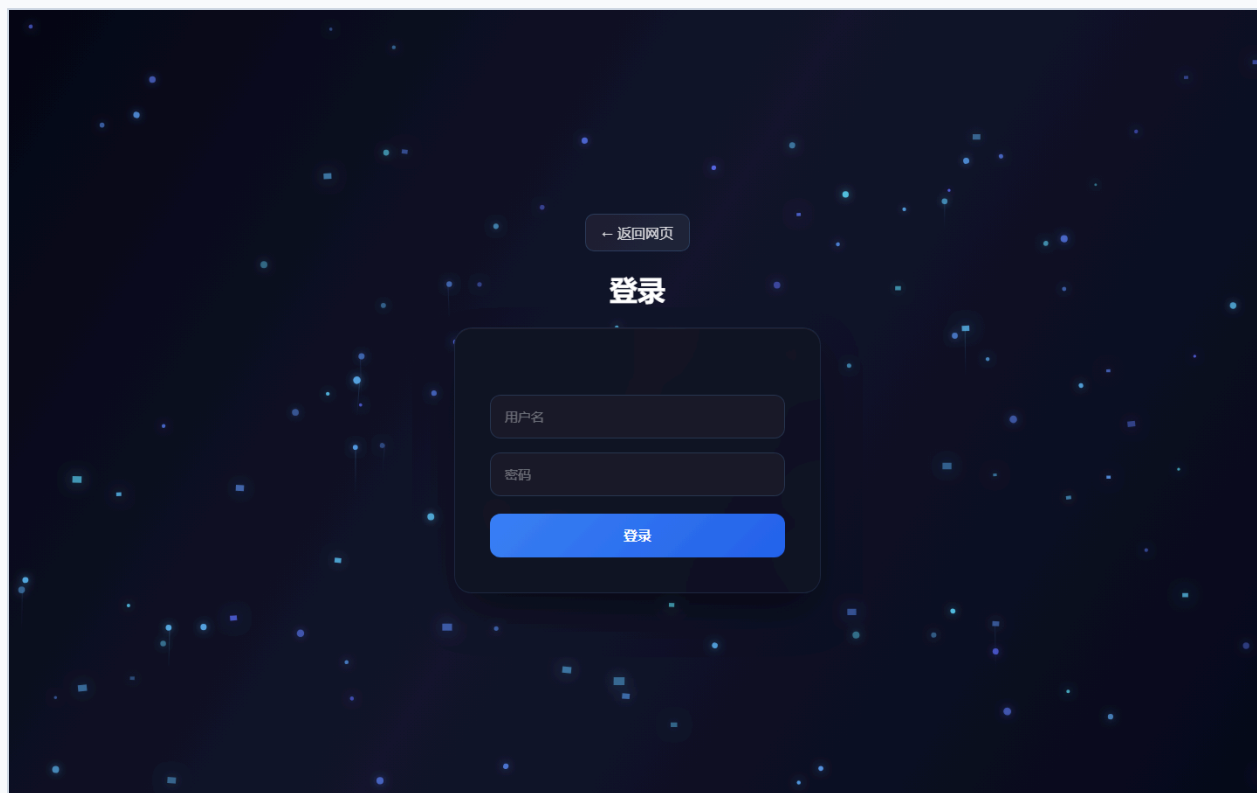
5. 修复后验证

使用攻击方原始步骤重新测试：

1. 发送原始无害测试参数。
2. 观察状态码、页面、数据、文件和日志。
3. 确认原攻击失效并保存截图。

验证结果：登录前后 Session 值发生变化；Cookie 具备 HttpOnly、SameSite=Lax；退出后访问核心 API 返回401。

原攻击是否失效：是（本机回归测试）



云 个人网盘

首页文件相册传输分享

搜索文件、图片、视频

退出登录

纯

上传文件



野兽先辈
下北泽电子科技大学 学生

你的个人云盘首页

集中管理课程资料、图片、视频和个人文件。这里保留了原 profile 页面里的头像与视频内容，并改造成网盘首页布局。

24
年龄

1919114514
学号

VibeCoding
兴趣标签

开始上传

文件列表

全部文件

图片
视频
文档
收藏
回收站

空间使用

42.6 GB

已使用 42%，剩余空间充足

图片文件

排序

筛选





最近文件

列表

名称	类型	修改时间	大小
 课程资料	文件夹	今天 16:40	--
 数据库作业说明.docx	文档	昨天 21:18	1.8 MB
 首页设计参考.png	图片	5 月 16 日	3.4 MB
 项目演示视频.mp4	视频	5 月 15 日	128 MB

pyknb 的文件

上传新文件

返回个人主页

退出登录

文件名	操作
44286_2023_2_Fig5_HTML.webp	下载 删除
fake.png	下载 删除
scriptalert1_script.png	下载 删除

[← 返回网页](#)

登录

用户名

密码

登录

任务 09 修复代码证据

gets.py:195-215

```
195         if user and user[1].startswith(("pbkdf2:", "bcrypt:"))
196             else bool(user) and user[1] == password
197     )
198     if not valid:
199         record_login_failure(username)
200         response = {"error": "用户名或密码错误"}
201         return (jsonify(response), 401) if as_api else ("用户名或密码错误", 401)
202     clear_login_failures(username)
203     session.clear()
204     csrf_token()
205     session["username"] = username
206     if user and not user[1].startswith(("pbkdf2:", "bcrypt:")):
207         conn = get_db_connection()
208         try:
209             with conn.cursor() as cursor:
210                 cursor.execute("UPDATE users SET password=%s WHERE username=%s", (generate_password_hash(password), username))
211             conn.commit()
212         finally:
213             conn.close()
214     security_logger.info("login_success username=%s ip=%s", username, client_ip())
215     if as_api:
```

gets.py:238-258

```
238
239 @app.post("/api/logout")
240 @csrf_protected
241 def api_logout():
242     session.clear()
243     return jsonify({"success": True})
244
245
246 @app.get("/profile")
247 def profile():
248     if "username" not in session:
249         return redirect("/login")
250     return render_template("profile.html")
251
252
253 @app.get("/logout")
254 def logout():
255     session.clear()
256     security_logger.info("logout ip=%s", client_ip())
257     return redirect("/")
258
```

6. 额外加固

统一错误提示、输入长度限制、安全日志、Cookie 安全属性、调试模式关闭和生产密钥配置要求。

7. 仍需改进

课程组别、负责人、Git tag 等元数据需在提交前填写；HTTPS 部署时启用 Secure Cookie；Web 服务器需确认上传目录不可执行。